

Botium Toys: Alcance, objetivos e informe de evaluación de riesgos

Alcance y objetivos de la auditoría

Alcance: El alcance de esta auditoría se define como el programa de seguridad completo de Botium Toys. Esto incluye sus activos, como equipos y dispositivos de los empleados, su red interna y sus sistemas. Deberá revisar los activos que tiene Botium Toys y los controles y prácticas de cumplimiento que tiene implementados.

Objetivos: Evaluar los activos existentes y completar la lista de verificación de controles y cumplimiento para determinar qué controles y prácticas recomendadas de cumplimiento deben implementarse para mejorar la postura de seguridad de Botium Toys.

Activos actuales

Los activos administrados por el Departamento de TI incluyen:

Equipos locales para las necesidades comerciales en la oficina

Equipos de los empleados: dispositivos de usuario final (computadoras de escritorio/portátiles, teléfonos inteligentes), estaciones de trabajo remotas, auriculares, cables, teclados, ratones, estaciones de acoplamiento, cámaras de vigilancia, etc.

Productos de escaparate disponibles para la venta minorista en el sitio y en línea; almacenados en el almacén contiguo de la empresa

Gestión de sistemas, software y servicios: contabilidad, telecomunicaciones, base de datos, seguridad, comercio electrónico y gestión de inventario

Acceso a Internet

Red interna

Retención y almacenamiento de datos

Mantenimiento de sistemas heredados: sistemas al final de su vida útil que requieren supervisión humana

Evaluación de riesgos

Descripción de riesgos

Actualmente, existe una gestión inadecuada de los activos. Además, Botium Toys no cuenta con todos los controles adecuados y es posible que no cumpla plenamente con las normas y regulaciones estadounidenses e internacionales.

Mejores prácticas de control

La primera de las cinco funciones del CSF del NIST es Identificar. Botium Toys deberá dedicar recursos a identificar los activos para poder gestionarlos adecuadamente. Además, deberá clasificar los activos existentes y determinar el impacto de la pérdida de los activos existentes, incluidos los sistemas, en la continuidad del negocio.

Puntuación de riesgo

En una escala del 1 al 10, la puntuación de riesgo es 8, que es bastante alta. Esto se debe a la falta de controles y de adhesión a las mejores prácticas de cumplimiento. Comentarios adicionales

El impacto potencial de la pérdida de un activo se clasifica como medio, porque el departamento de TI no sabe qué activos estarían en riesgo. El riesgo de que se produzcan multas por parte de los organismos reguladores es alto porque Botium Toys no cuenta con todos los controles necesarios y no cumple plenamente con las mejores prácticas relacionadas

con las normas de cumplimiento que mantienen la privacidad y seguridad de los datos críticos. Revise los siguientes puntos para obtener detalles específicos:

Actualmente, todos los empleados de Botium Toys tienen acceso a los datos almacenados internamente y pueden acceder a los datos de los titulares de tarjetas y a la información personal identificable (PII) y la información personal identificable (SPII) de los clientes. Actualmente, no se utiliza el cifrado para garantizar la confidencialidad de la información de las tarjetas de crédito de los clientes que se acepta, procesa, transmite y almacena localmente en la base de datos interna de la empresa.

No se han implementado controles de acceso relacionados con el privilegio mínimo y la separación de funciones.

El departamento de TI ha garantizado la disponibilidad y ha integrado controles para garantizar la integridad de los datos.

El departamento de TI tiene un cortafuegos que bloquea el tráfico en función de un conjunto de reglas de seguridad definidas adecuadamente.

El departamento de TI instala y supervisa periódicamente un software antivirus. El departamento de TI no ha instalado un sistema de detección de intrusiones (IDS).

Actualmente no hay planes de recuperación de desastres en marcha y la empresa no tiene copias de seguridad de los datos críticos.

El departamento de TI ha establecido un plan para notificar a los clientes de la UE en un plazo de 72 horas si se produce una violación de seguridad. Además, se han desarrollado políticas, procedimientos y procesos de privacidad que se aplican entre los miembros del departamento de TI y otros empleados para documentar y mantener los datos de forma adecuada.

Aunque existe una política de contraseñas, sus requisitos son nominales y no están en línea con los requisitos mínimos actuales de complejidad de contraseñas (por ejemplo, al menos ocho caracteres, una combinación de letras y al menos un número; caracteres especiales).

No hay un sistema de gestión de contraseñas centralizado que haga cumplir los requisitos mínimos de la política de contraseñas, lo que a veces afecta a la productividad cuando los empleados o proveedores envían un ticket al departamento de TI para recuperar o restablecer una contraseña.

Si bien los sistemas heredados se supervisan y mantienen, no hay un cronograma regular establecido para estas tareas y los métodos de intervención no están claros.

La ubicación física de la tienda, que incluye las oficinas principales de Botium Toys, el frente de la tienda y el almacén de productos, cuenta con cerraduras suficientes, vigilancia por circuito cerrado de televisión (CCTV) actualizada, así como sistemas de detección y prevención de incendios en funcionamiento.